

Gruppenaufgabe 3 | Prüfung, Testing und die 3-2-1 Regel

Szenario

Die «SwissMediCare AG», ein regionaler Gesundheitsverbund, wurde Opfer einer schweren Ransomware-Attacke. Die IT-Abteilung stellte mit Entsetzen fest, dass das Backup-System ebenfalls verschlüsselt wurde. Nun beauftragt Sie die Klinikleitung, die bestehende Sicherungsarchitektur schonungslos zu analysieren, ein zukunftssicheres 3-2-1-1-0 Konzept zu entwerfen und einen konkreten Testplan aufzubauen, damit ein solches Desaster nie wieder geschieht.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Das erweiterte 3-2-1-1-0 Konzept analysieren und in einer konkreten IT-Umgebung anwenden.
- Detaillierte Backup-Testverfahren (Integrität, Anwendung, Zeitanalyse) unterscheiden und planen.
- Eine Fehlerkultur etablieren, indem Sie aus fehlgeschlagenen Szenarien verbindliche Optimierungsprozesse ableiten.

Arbeitsauftrag

Skizzieren Sie für die «SwissMediCare AG» das neue 3-2-1-1-0 Sicherungskonzept, indem Sie die Speichermedien und Standorte konkret benennen. Entwickeln Sie anschliessend einen pragmatischen Testkalender für das kommende Jahr, der aufzeigt, wann welche Art von Test (Restore, Tabletop, Volltest) durchgeführt wird, ohne den Klinikbetrieb zu gefährden.

Ergebnis

Präsentieren Sie Ihr Architektur-Konzept (als Diagramm oder Stichwortliste) und den Jahres-Testkalender in Form eines strukturierten Flipcharts. Dauer der Vorstellung: max. 4 Minuten.

Musterlösung A | Gruppenaufgabe 3 | Prüfung, Testing und die 3-2-1 Regel

Ansatz: Strukturiert-analytisch

1. Architekturanalyse und Einführung des 3-2-1-1-0 Konzepts

Der Vorfall bei der «SwissMediCare AG» ist ein klassisches Beispiel für ein unzureichendes Sicherheitsnetz. Ein einfaches Backup auf demselben Netzwerk-Storage reicht bei modernen Ransomware-Angriffen nicht aus, da die Schadsoftware verbundene Netzlaufwerke sucht und ebenfalls verschlüsselt. Wir lösen dieses Problem durch die strikte Implementierung der erweiterten 3-2-1-1-0 Regel.

2. Konzeptionelle Umsetzung bei der SwissMediCare AG

Wir definieren die Infrastruktur anhand der fünf Regelbausteine strukturiert neu:

- **3 (Drei Kopien der Daten):** Die Klinik hält künftig drei Versionen der Patientendossiers und Kliniksysteme. (1x Produktivdaten auf dem Haupt-Flash-Storage, 2x Backup-Kopien).
- **2 (Zwei unterschiedliche Medien):** Die Backups werden nicht auf demselben Medientyp gespeichert. Kopie A liegt auf einem schnellen Disk-basierten Backup-Appliance (für schnelle Wiederherstellungen). Kopie B wird auf moderne LTO-9 Magnetbänder geschrieben. Dies sichert uns gegen serielle Hardware-Defekte ab.
- **1 (Ein Aussenstandort):** Das Disk-Backup-Appliance steht im Hauptgebäude der Klinik. Die Magnetbänder werden jedoch einmal pro Woche durch einen Kurierdienst in einen feuerfesten Tresor in einer anderen Gemeinde gefahren. So sind wir gegen einen Totalverlust des Hauptgebäudes abgesichert.
- **1 (Ein Offline- oder Immutability-Speicher):** Hier schliessen wir das Sicherheitsleck der letzten Ransomware-Attacke. Wir konfigurieren ein S3-kompatibles Objektspeicher-System mit aktivierter "Immutability" (Unveränderbarkeit). Daten, die dorthin geschrieben werden, können für 30 Tage weder gelöscht noch verändert oder überschrieben werden – nicht einmal vom Systemadministrator. Wenn ein Hacker das System kapert, scheitert der Verschlüsselungsversuch an der Hardware-Sperre. Alternativ zählen hier auch die physisch ausgelagerten Bänder, die im Regal liegen (Air-Gap).
- **0 (Null Fehler durch automatisierte Verifikation):** Wir implementieren die Software-Funktion "SureBackup" (oder vergleichbare). Das System startet nach jedem Backup eine virtuelle Maschine isoliert in einer Sandbox (Bubble), bootet das Betriebssystem, prüft den Datenbank-Dienst auf Fehler, erstellt einen Bericht und beendet die Maschine wieder. So garantieren wir 0 Fehler.

3. Testkalender und Qualitätssicherung (Jahresplan)

Die beste Architektur ist nutzlos ohne strukturierte Kontrollen. Der Testkalender für die Klinik wird wie folgt definiert:

- **Täglich:** Vollautomatisierte Überprüfung der Backup-Logs und Integritätsprüfung (0-Fehler-Garantie) durch die Backup-Software in der Sandbox.
- **Monatlich:** Granularer Restore-Test. Ein IT-Mitarbeiter muss aus einer zufällig ausgewählten Abteilung eine gelöschte Datei oder E-Mail wiederherstellen. Dauer: max. 15 Minuten. Protokollierung des Ergebnisses.
- **Quartalsweise:** Tabletop-Übung des Krisenstabs (IT-Leitung, Klinikleitung, Kommunikation). Es wird ein fiktives Szenario am Tisch durchgespielt (z.B. "Ein Arzt hat versehentlich einen USB-Stick mit Malware eingesteckt"). Die Kommunikationsketten und Notfallhandbücher werden theoretisch validiert.
- **Jährlich (Wochenende):** Disaster Recovery Teilumschaltung. Ein isolierter Bereich (z.B. ein nicht kritisches Abrechnungssystem) wird im Hauptnetz getrennt und aus der Offline-Kopie im Notfallnetzwerk wieder hochgefahren. Die SLA-Zeiten (RTO) werden gestoppt

und mit den Zielvorgaben abgeglichen.

4. Fazit und Fehlerkultur

Durch die architektonische Trennung (Air-Gap / Immutability) und den rigorosen, mehrstufigen Testplan verwandeln wir das Netzwerk der Klinik von einer anfälligen Umgebung in eine Festung. Essenziell ist hierbei die Einführung einer echten Fehlerkultur: Schlägt der jährliche Volltest fehl, wird niemand entlassen. Stattdessen wird der Test als voller Erfolg gewertet, da er eine Schwachstelle aufgedeckt hat, bevor der nächste Ransomware-Angreifer zuschlagen konnte.

Musterlösung B | Gruppenaufgabe 3 | Prüfung, Testing und die 3-2-1 Regel

Ansatz: Praxisnah-narrativ

1. Die Lektion aus dem Desaster

Liebe Klinikleitung der «SwissMediCare AG», wir alle erinnern uns an den schmerzhaften Blackout vor zwei Monaten. Das Patientensystem war tot, Termine mussten handschriftlich koordiniert werden, Operationen wurden verschoben. Der schlimmste Moment war jedoch, als die IT melden musste: "Der Erpressungstrojaner hat auch unseren Backup-Server verschlüsselt." Warum konnte das passieren? Weil der Backup-Server wie ein normales Laufwerk im Netzwerk hing. Der Trojaner hat ihn gefunden und zerstört. Wir haben daraus gelernt. Um das Vertrauen von Patienten und Personal wiederherzustellen, führen wir nun das Prinzip der absoluten Isolation ein: Das 3-2-1-0 Konzept.

2. Unser neues Sicherheitsnetzwerk

Vergessen wir komplizierte Theorie, schauen wir uns an, was ganz konkret mit einem Röntgenbild passiert, wenn es heute gespeichert wird:

Das Originalbild liegt auf dem Produktionsserver (**Kopie 1**).

Jede Nacht macht unser neues System ein Backup auf einen lokalen Backup-Server (**Kopie 2**). So weit, so normal. Aber jetzt kommt die Erweiterung: Einmal am Tag wird dieses Backup verschlüsselt in die Cloud der Swisscom übertragen (**Kopie 3 und Aussenstandort**). Wir haben also unterschiedliche Medien (Disk lokal und Cloud-Storage) genutzt.

Was rettet uns nun vor der Ransomware? Der Cloud-Speicher ist mit einem speziellen Schloss versehen, dem sogenannten Object-Lock (**Die Offline/Immutable Kopie**). Wir haben vertraglich festgelegt, dass einmal geschriebene Daten dort für 60 Tage wie in Stein gemeisselt sind. Wenn nun ein Hacker bei uns eindringt und den Befehl "Alles löschen" in die Cloud sendet, blockiert das System diese Anweisung hart auf Hardwareebene. Die Daten sind unangreifbar.

Und die 0? Das bedeutet null Vertrauen in die Technik ohne Kontrolle. Früher haben wir uns auf das grüne Häkchen in der Bestätigungs-E-Mail verlassen. Ab sofort bootet unser System das Backup der Patientendatenbank jede Nacht heimlich und völlig abgeschottet im Hintergrund hoch. Es schaut, ob das Windows startet und ob die Datenbank ansprechbar ist. Erst wenn dieser Praxistest gelingt, bekommen wir das grüne Häkchen.

3. Wie wir in Zukunft den Ernstfall proben

Ein System ist nur so gut wie der Mensch, der es bedient. In der Krisensituation herrscht Panik. Da liest niemand ein 100-seitiges Handbuch. Daher führen wir einen radikalen Testkalender ein:

- **Die wöchentliche "Feuerwehübung":** Jeden Freitagmorgen bekommt ein Techniker im Helpdesk den Auftrag: "Lösche das Dokument X im Marketing-Laufwerk und hol es zurück." Wenn er länger als 10 Minuten braucht, müssen wir nachbessern.
- **Die Tabletop-Sitzung (Halbjährlich):** Wir setzen uns mit der Klinikleitung bei Kaffee und Gipfeli zusammen. Ich werfe einen Würfel. Bei einer 6 brennt der Serverraum. Bei einer 3 haben wir Ransomware im Haus. Dann fragen wir reihum: Wer ruft wen an? Wo liegen die Notfallpläne (hoffentlich gedruckt!)? Wie informieren wir die Patienten? Das schärft den Verstand für die echten Krisen.
- **Der Ernstfall-Test (Jährlich):** Einmal im Jahr, am Samstagabend, ziehen wir sprichwörtlich den Stecker vom unkritischen Intranet-Server. Die IT muss beweisen, dass sie das System aus dem manipulationssicheren Cloud-Speicher laden und starten kann.

4. Die neue Philosophie: Fehler sind unsere Freunde

Die wichtigste Botschaft an das gesamte IT-Team lautet: Wir wollen beim Testen scheitern! Wenn der jährliche Ernstfall-Test nicht auf Anhieb klappt, weil ein Passwort nicht dokumentiert war oder eine Lizenz fehlte, dann feiern wir das. Denn wir haben den Fehler an einem ruhigen Samstagabend gefunden und nicht an einem Dienstagmorgen während einer laufenden Herz-OP bei einem echten Hackerangriff. Jede gefundene Schwäche wird sofort im Notfallhandbuch aktualisiert. So werden wir Monat für Monat robuster.